

Eng 3.2. Linux System Hardening

Task 1 - Introduction

Linux systems provide a reliable and robust alternative to closed-source systems, such as MS Windows Server and UNIX. Moreover, choosing Linux can help cut down licensing costs dramatically.

Task 2 - Physical Security

GRUB stands for Grand Unified Bootloader. It is available from the GNU project and is a common bootloader shipped with many Linux distributions.

If an intruder can access the system physically, it is a non-sophisticated task to use GRUB, a popular Linux bootloader, to reset the root password account. Hence we have the adage “boot access = root access”. It is evident that we need to ensure physical security for our computer systems; however, in the unlikely event that physical security is breached, we need to provide additional layers of protection. Many BIOS and UEFI firmware allows you to add a boot password. This password will prevent unauthorised users from booting the system. However, this can only be used for personal systems; it won't make sense to use it on servers as this will require someone to be physically present to supply the boot password.

We can consider adding a GRUB password depending on the Linux system we want to protect. Many tools help achieve that. One tool is `grub2-mkpasswd-pbkdf2`, which prompts you to input your password twice and generates a hash for you. The resulting hash should be added to the appropriate configuration file depending on the Linux distribution. This configuration would prevent unauthorised users from resetting your root password. It will require the user to supply a password to access advanced boot configurations via GRUB, including logging in with root access.

It is important to note that adding a password for GRUB is not available for systems deployed using cloud service providers (such as our Linux VM);

a GRUB password does not make sense as you don't have access to the physical terminal.

Ensuring proper physical security is a must considering how easy it is for an attacker with physical access to wreak havoc. Adding a password to GRUB is a reasonable measure to block users with physical access to a system's keyboard from gaining access. However, we need a plan in case an attacker finds a way to steal the disk drives.

```
root@AttackBox# grub2-mkpasswd-pbkdf2
Enter password:
Reenter password:
PBKDF2 hash of your password is grub.pbkdf2.sha512.10000.534B
77859C1
```

Answer the questions below

| What command can you use to create a password for the GRUB bootloader?

grub2-mkpasswd-pbkdf2

| What does PBKDF2 stand for?

Password-Based Key Derivation Function 2

Task 3 - Filesystem Partitioning and Encryption

Encryption makes data unreadable without the decryption key. There are various software systems and tools that provide encryption to Linux systems. Since many modern Linux distributions ship with LUKS (Linux Unified Key Setup).

Linux Unified Key Setup (LUKS) is a cryptographic disk encryption standard for Linux systems. It uses symmetric and asymmetric encryption to protect data on encrypted disks and partitions. LUKS is a versatile encryption method that can be used to encrypt any block device, including hard drives, USB drives, and even entire operating systems. LUKS phdr: It stands for LUKS Partition Header. LUKS phdr stores information about the UUID (Universally Unique Identifier), the used cipher, the cipher mode, the key length, and the checksum of the master key.

Answer the questions below

What does LUKS stand for?

Linux Unified Key Setup

We cannot attach external storage to the VM, so we have created a `/home/tryhackme/secretvault.img` file instead. It is encrypted with the password `2N9EdZYNksEE3Ad`. To access it, you need to open it using `cryptsetup` and then mount it to an empty directory, such as `myvault`.

What is the flag in the secret vault?

THM{LUKS_not_LUX}

```
sudo cryptsetup open --type luks secretvault.img myvault && s
udo mount /dev/mapper/myvault myvault/ (mounted /dev/mapper/m
yvault)
password 2N9EdZYNksEE3Ad
tryhackme@ip-10-113-107-70: cd myvault/
tryhackme@ip-10-113-107-70: ls
tryhackme@ip-10-113-107-70: cat task3_flag.txt
```

Task 4 - Firewall

The first Linux firewall was a packet filtering firewall, i.e., a stateless firewall. A stateless firewall can inspect certain fields in the IP and TCP/UDP headers to decide upon a packet but does not maintain information about ongoing TCP connections. As a result, a packet can manipulate a few TCP flags to appear as if it is part of an ongoing connection and evade certain restrictions. Current Linux firewalls are stateful firewalls; they keep track of ongoing connections and restrict packets based on specific fields in the IP and TCP/UDP headers and based on whether the packet is part of an ongoing connection.

UFW stands for uncomplicated firewall. It configures the firewall to `allow` traffic to TCP port 22. It is a front-end for managing iptables or nftables firewall rules.

```
root@ip-10-113-107-70:~# ufw status
Status: inactive
```

There is a firewall running on the Linux VM. It is allowing port 22 TCP as we can ssh into the machine. It is allowing another TCP port; what is it? 12526

```
root@ip-10-113-107-70:~# sudo ufw status
```

```
Status: active

To Action From
--
22/tcp ALLOW Anywhere
14298/udp ALLOW Anywhere
12526/tcp ALLOW Anywhere
22/tcp (v6) ALLOW Anywhere (v6)
14298/udp (v6) ALLOW Anywhere (v6)
12526/tcp (v6) ALLOW Anywhere (v6)
```

Answer the questions below

| What is the allowed UDP port?

14298

Task 5 - Remote Access

Providing remote access to a system is a very convenient way to access your system and files when you are not physically present at the target system's keyboard. Common attacks include:

1. Password sniffing
2. Password guessing and brute-forcing
3. Exploiting the listening service

Protecting Against Password Sniffing: Remote access can be achieved through many different protocols and services. Although all modern systems use encrypted protocols, such as the SSH protocol, for remote access, older systems might still use cleartext protocols, such as the Telnet protocol.

Protecting Against Password Guessing: When you set up your Linux system with SSH for remote administration, you also make your Linux box available for all interested parties. Many malicious hackers search the Internet for listening SSH servers and start to guess the login credentials; usually, they try `root` with the most common passwords.

```
tryhackme@ip-10-113-107-70: /myvault$ vim /etc/ssh/sshd_config
```

Answer the questions below

| What flag is hidden in the sshd_config file?

THM{secure_SEA_shell}

Task 6 - Securing User Accounts

The `root` account carries with it tremendous power and hence risk. You are at risk of rendering your system unbootable with a simple mistake.

Use sudo: To avoid logging in as `root`, the better approach would be to have an account -created for administrative purposes- added to the *sudoers*, i.e. group who can use the `sudo` command. `sudo` stands for Super User Do and it should precede any command that requires `root` privileges.

Disable root: Once you have created an account for administrative purposes and added it to the `sudo / wheel` group, you might consider disabling the `root` account. A straightforward way is to modify the `/etc/passwd` and change the `root` shell to `/sbin/nologin`. In other words, edit `/etc/passwd` and change the line `root:x:0:0:root:/root:/bin/bash` to `root:x:0:0:root:/root:/sbin/nologin`.

Disable Unused Accounts: As part of system maintenance, it is vital to disable user accounts that no longer need access to the system in question. For instance, these users might have moved to another department or quit the company. You can disable a user account in the same way we would disable the root account. An easy way would be to edit the `/etc/passwd` file and set the shell of the user account we want to disable to `/sbin/nologin`.

One way to disable an account is to edit the passwd file and change the account's shell. What is the suggested value to use for the shell? /sbin/nologin

Answer the questions below

| What is the name of the RedHat and Fedora systems sudoers group?

wheel

| What is the name of the sudoers group on Debian and Ubuntu systems?

sudo

| Other than tryhackme and ubuntu, what is the username that belongs to the sudoers group?

blacksmith

```
tryhackme@ip-10-113-107-70:~/myvault$ cat etc/group | grep sudo
```

Task 7 - Software and Services

Every piece of software you install on your system also increases the number of potential vulnerabilities. In other words, installing additional software packages and new services increases the vulnerabilities an attacker can exploit to gain access to your system and, eventually, to other systems on your network. You can follow some guidelines to help you reduce the attack surface:

Disable Unnecessary Services,

Block Unneeded Network Ports,

Avoid Legacy Protocols,

Remove Identification Strings,

Besides FTPS, what is another secure replacement for TFTP and FTP? SFTP (At one point in the past, Telnet was the primary protocol to remote access a system; the TFTP protocol was commonly used to transfer files. Such protocols should no longer be allowed as secure alternatives have been released. Instead of Telnet,

the SSH protocol is now widely available. For example, the Secure File Transfer Protocol (SFTP) protocol provides a great alternative to the TFTP protocol. The critical point is that a secure alternative is selected and used.

Task 8 - Update and Upgrade Policies

It is vital that you keep your system updated with the latest security patches and bug fixes.

You can update a Debian-based distribution, such as Ubuntu, with the following two commands:

1. `apt update` to download package information from the configured sources
2. `apt upgrade` to install available upgrades for all packages from the configured sources

You can update a RedHat or Fedora system using the following:

- `dnf update` on newer releases (Red Hat Enterprise Linux 8 and later)
- `yum update` on older releases (Red Hat Enterprise Linux 7 and earlier)

Kernel Updates: Updating the system should not be limited to the installed software; it should consider updating the kernel. For instance, in 2016, a security vulnerability that affects the Linux kernel was discovered. It allows an attacker to gain root access to a system by exploiting a race condition in the copy-on-write (COW) mechanism, giving it the name "Dirty COW." The vulnerability is present in all Linux kernel versions from 2.6.22 onwards. It has been patched in most major Linux distributions, but it is still a threat to systems that have not been updated. Because Dirty COW is a severe vulnerability that can allow attackers to gain root access to Linux systems, it is crucial to keep your system, including its kernel, up-to-date with the latest security patches to reduce the risk of exploitation.

Automatic Updates: Now that you have a Linux system with security updates throughout its life, we must ensure that the updates are properly installed, and security fixes are applied.

- Stay updated with security news in case of a vulnerability that affects your systems is disclosed.

- Depending on the Linux distribution that you are using, consider configuring automatic updates. Automating updates on Linux distributions that prioritize stability over cutting-edge technology would be safe.

uname -a: It prints information about the operating system and kernel.

Answer the questions below

| What command would you use to update an older Red Hat system?

yum update

| What command would you use to update a modern Fedora system?

dnf update

| What two commands are required to update a Debian system?

apt update && apt upgrade

| What does yum stand for?

Yellowdog Updater, Modified

| What does dnf stand for?

Dandified YUM

| What flag is hidden in the sources.list file?

THM{not_Advanced_Persistent_Threat}

find / -name sources.list 2>/dev/null

tryhackme@ip-10-113-107-70:~# / vault vim /etc/apt/sources.list

Task 9 - Audit and Log Configuration

Most log files on Linux systems are stored in the `/var/log` directory. Here are a few of the logs that can be referenced when looking into threats:

- `/var/log/messages` - a general log for Linux systems

- `/var/log/auth.log` - a log file that lists all authentication attempts (Debian-based systems)
- `/var/log/secure` - a log file that lists all authentication attempts (Red Hat and Fedora-based systems)
- `/var/log/utmp` - an access log that contains information regarding users that are currently logged into the system
- `/var/log/wtmp` - an access log that contains information for all users that have logged in and out of the system
- `/var/log/kern.log` - a log file containing messages from the kernel
- `/var/log/boot.log` - a log file that contains start-up messages and boot information

We will keep this task short and include only two handy commands for large log files.

- Since new events are appended to the log file, you can view the last few lines using `tail`. For example, `tail -n 12 boot.log` will display the last 12 lines.
- One way to search log lines containing a specific keyword is using the command `grep`. For instance, `grep FAILED boot.log` will only show the lines with the word `FAILED`.

Note that you must be logged in as root or precede your commands with `sudo` to view the system log files.

Answer the questions below

| What command can you use to display the last 15 lines of kern.log?

tail -n 15 kern.log

| What command can you use to display the lines containing the word denied in the file secure?

grep denied secure

